WRITE UP WEEKLY CTF PRACTICE 03



NAMA: PUTU SATRIA NARAYANA WIDIARTHA

NIM: 260530911105

DIVISI: CYBER SECURITY

DAFTAR ISI

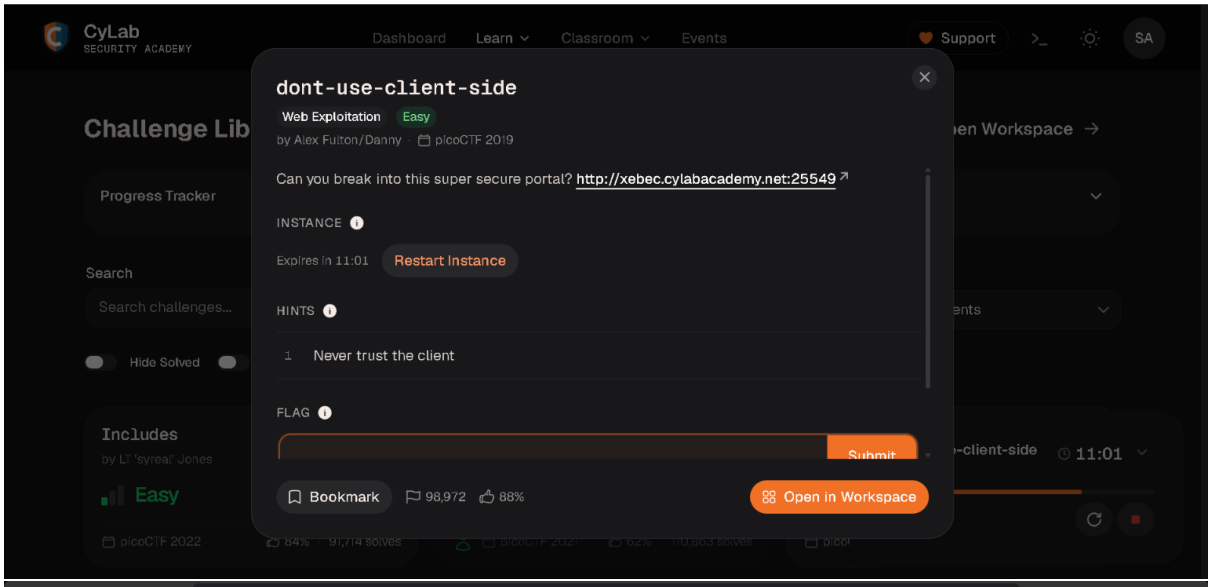
KATEGORI UTAMA: WEB 3
DON'T USE CLIENT SIDE 3
WHERE ARE THE ROBOTS 5
INCLUDES 6
SCAVENGER HUNT 9
GET AHEAD 13
SECRETS 15

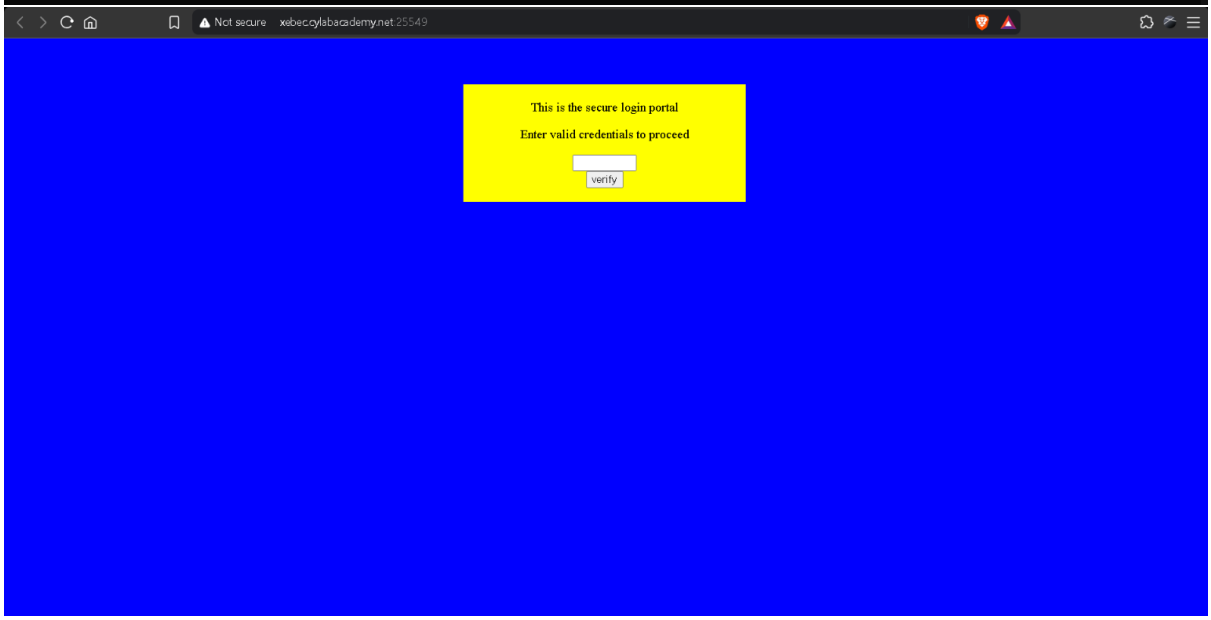
KATEGORI UTAMA: WEB

DON'T USE CLIENT SIDE

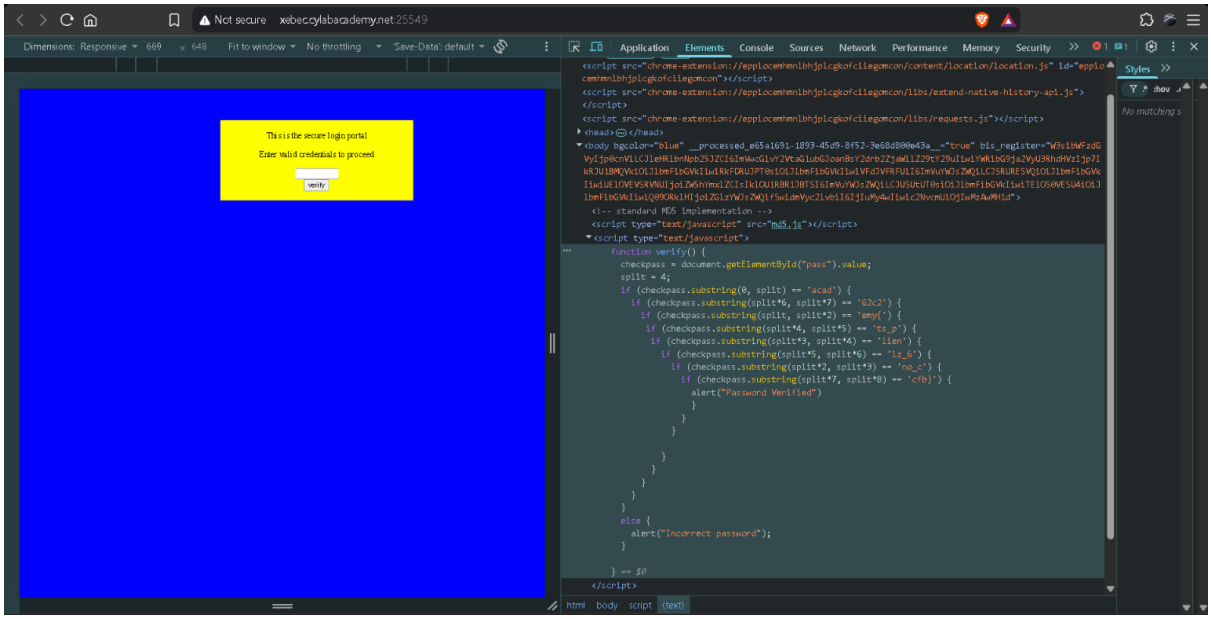
Membobol portal login sederhana dengan menganalisis kode JavaScript di sisi klien

Link: https://learn.cylabacademy.org/library/66

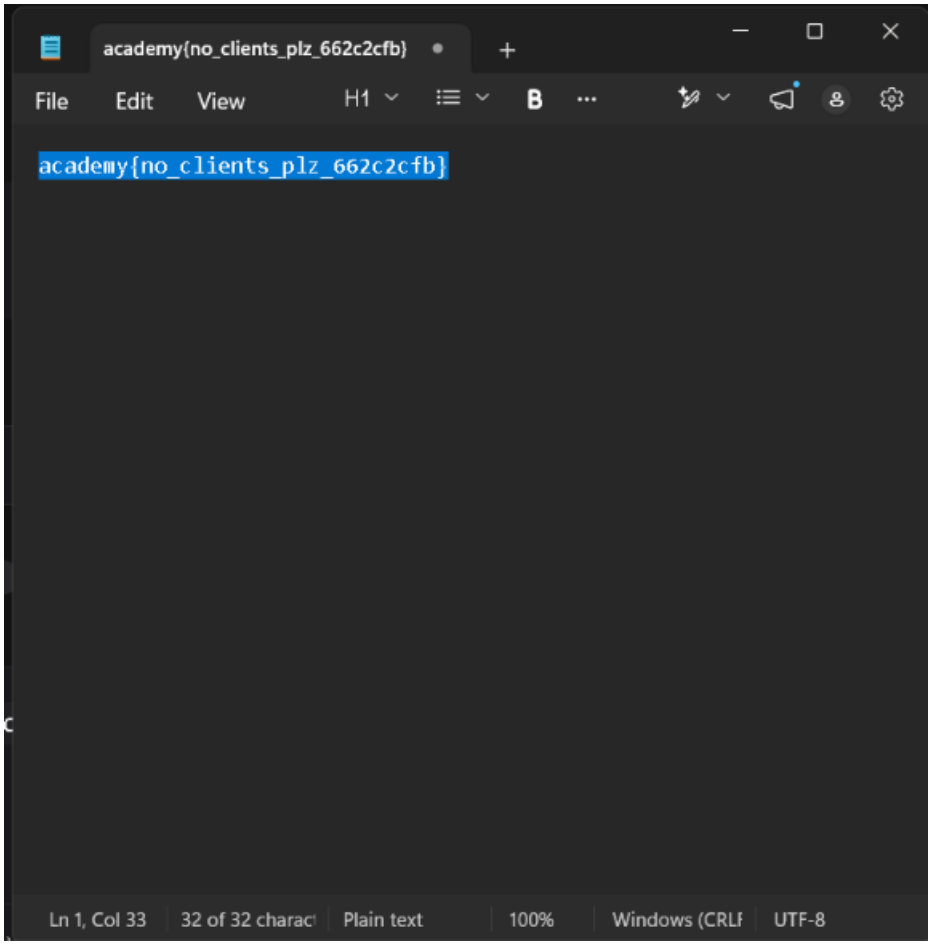




Buka terlebih dahulu halaman challenge dan ternyata kita disuruh login dengan kredensial untuk diproses.



Saya lalu membuka developer tools untuk melihat kodenya. Terlihat ada bagian javascript yang berisikan function verify untuk memproses kata sandi yang displit menjadi beberapa bagian.



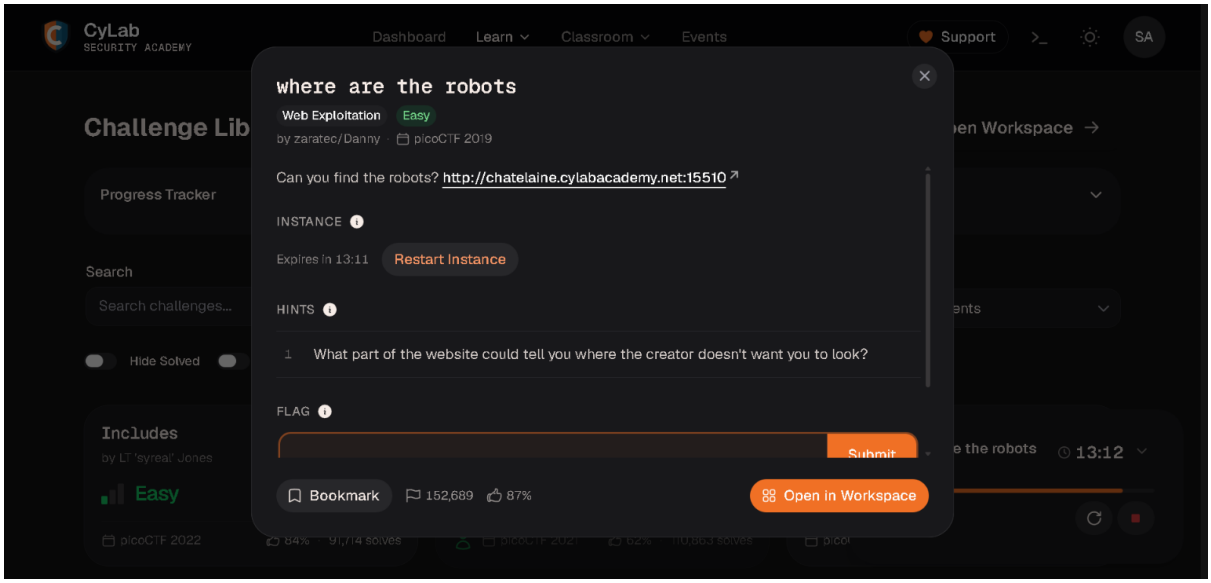
Rangkai keseluruhan flag dengan menggabungkan karater berdasarkan urutan index sususan karakter dari function verif yang tadi. Flag pun berhasil didapatkan.

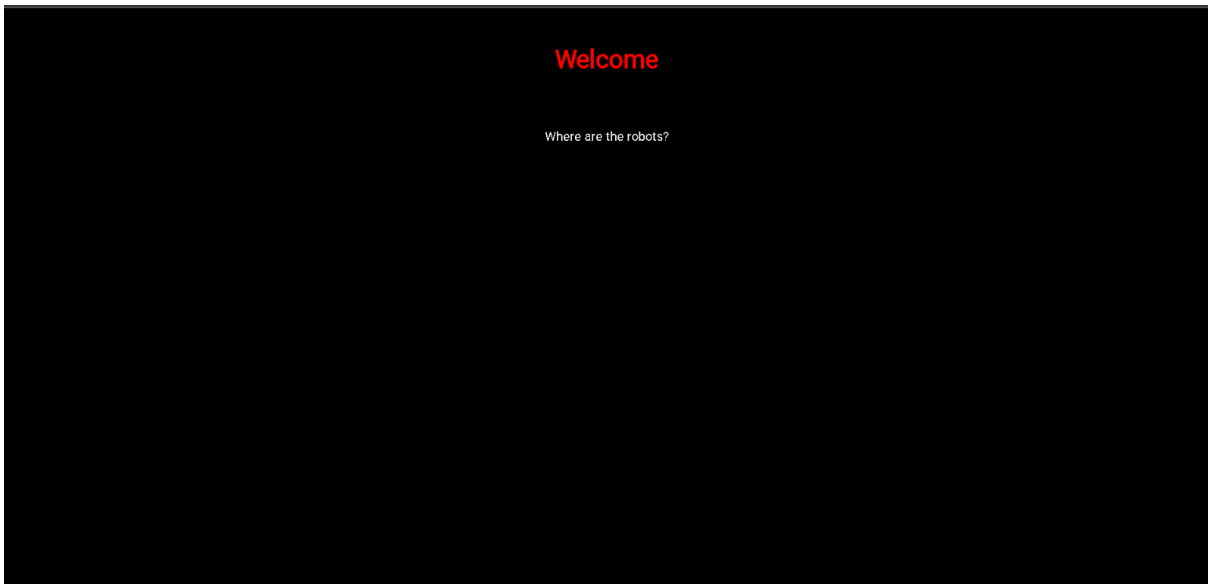
Flag: academy{no_clients_plz_662c2cfb}

WHERE ARE THE ROBOTS

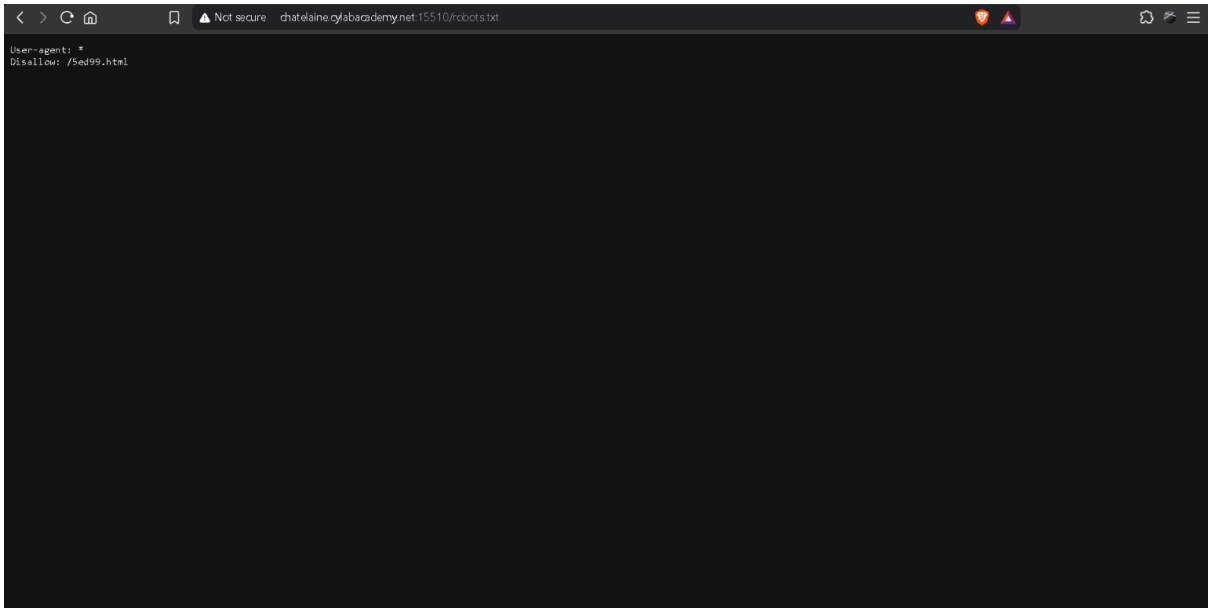
Mengajarkan bagaimana berkas robots.txt pada sebuah web server bekerja. Berkas robots.txt biasanya digunakan untuk memberitahu web crawler (bot mesin pencari) halaman mana saja yang tidak boleh diindeks.

Link: https://learn.cylabacademy.org/library/4

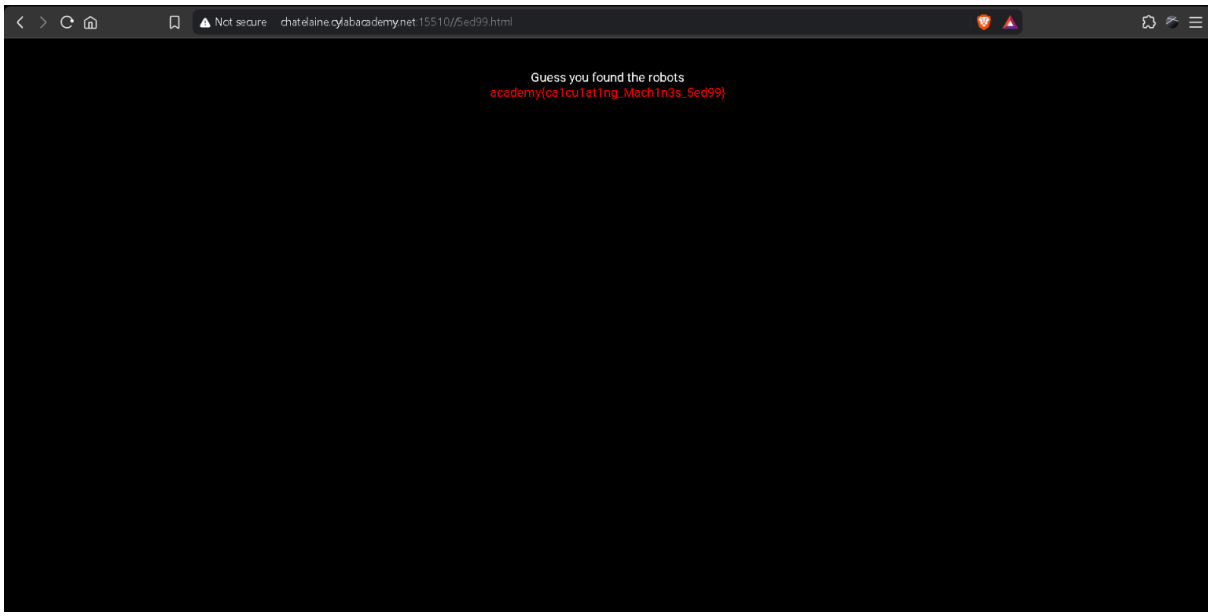




Web pada challenge ini menampilkan halaman “Welcome Where are the robots” yang merujuk ke file robots.txt dimana digunakan untuk memberitahu web crawler halaman mana saja yang tidak boleh diindeks. Namun, file ini bersifat publik dan sering kali secara tidak sengaja membocorkan direktori atau nama berkas tersembunyi.



Untuk mencari dan melihat file robots.txt, cukup tambahkan /robots.txt pada bagian belakang URL untuk melihat isi file robotsnya. Terlihat pada file robots.txt terdapat disallow pada path URL /5ed99.html.



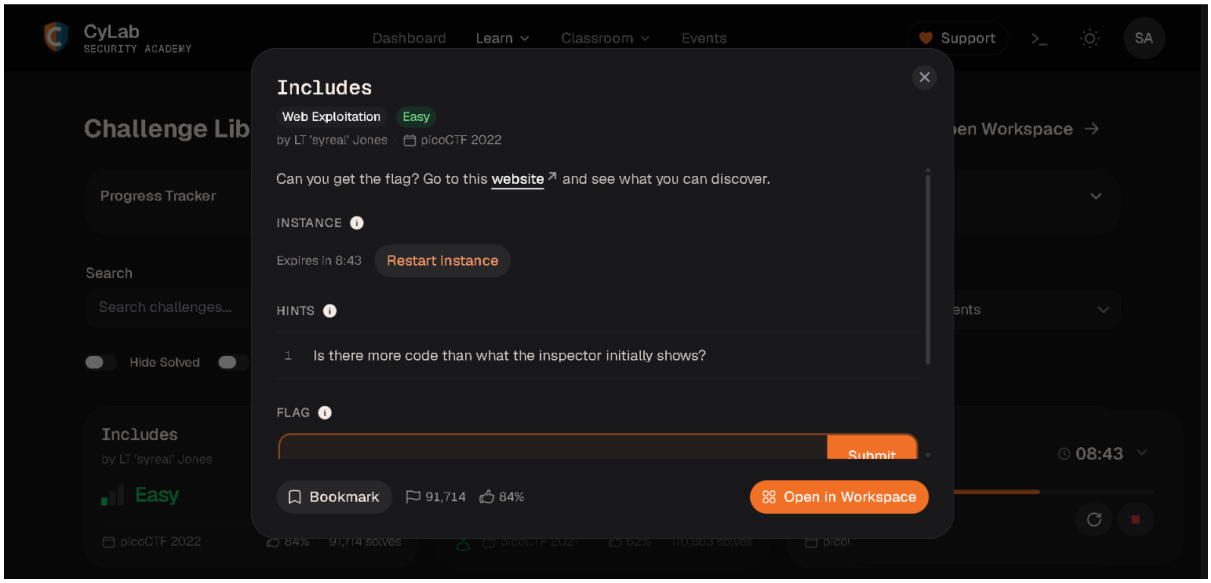
Saya mencoba membuka path html tersebut dan flagpun ditemukan.

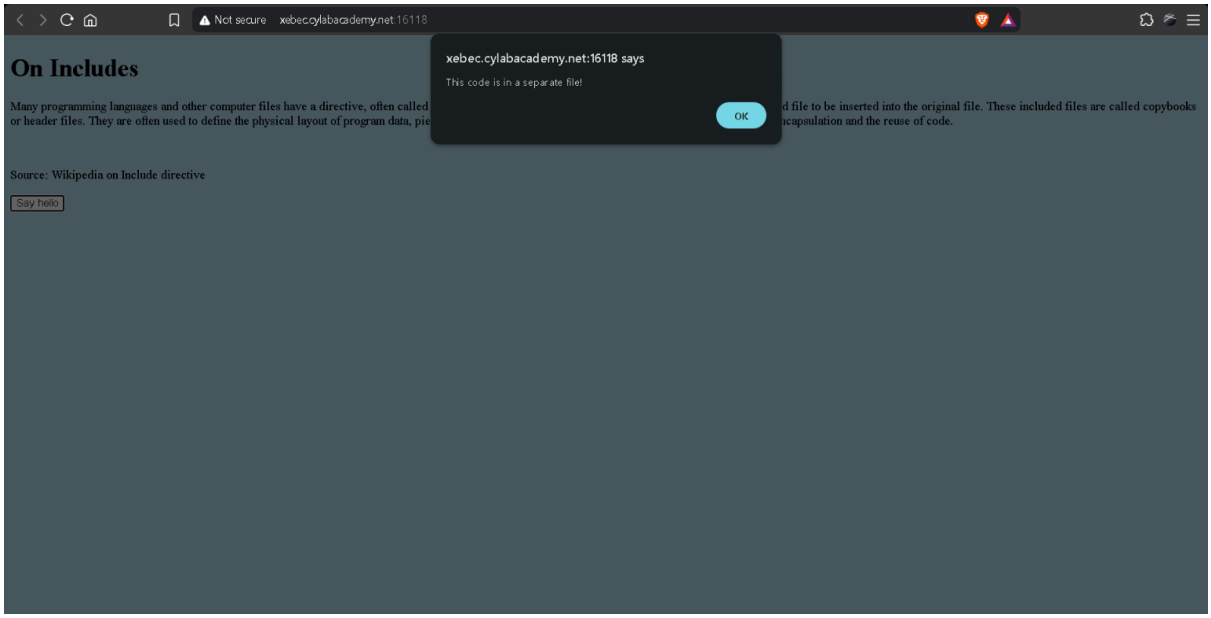
Flag: academy{ca1cu1at1ng_Mach1n3s_5ed99}

INCLUDES

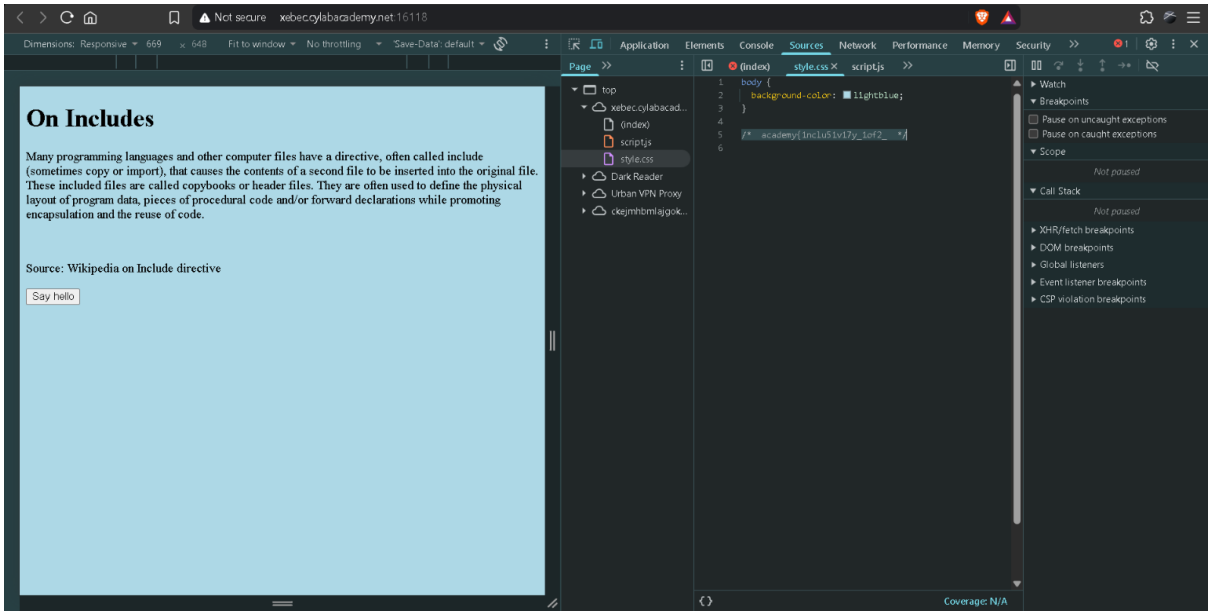
Memeriksa dan menggabungkan informasi dari beberapa file terpisah (seperti kode sumber web atau direktori file) untuk menemukan potongan flag yang tersembunyi.

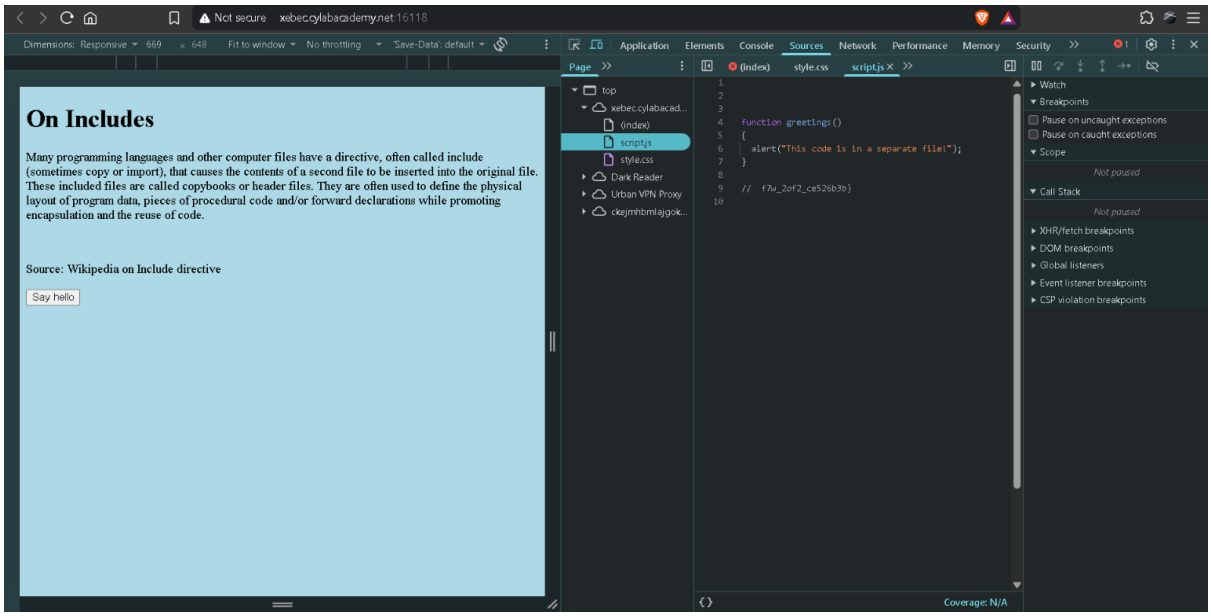
Link: https://learn.cylabacademy.org/library/274



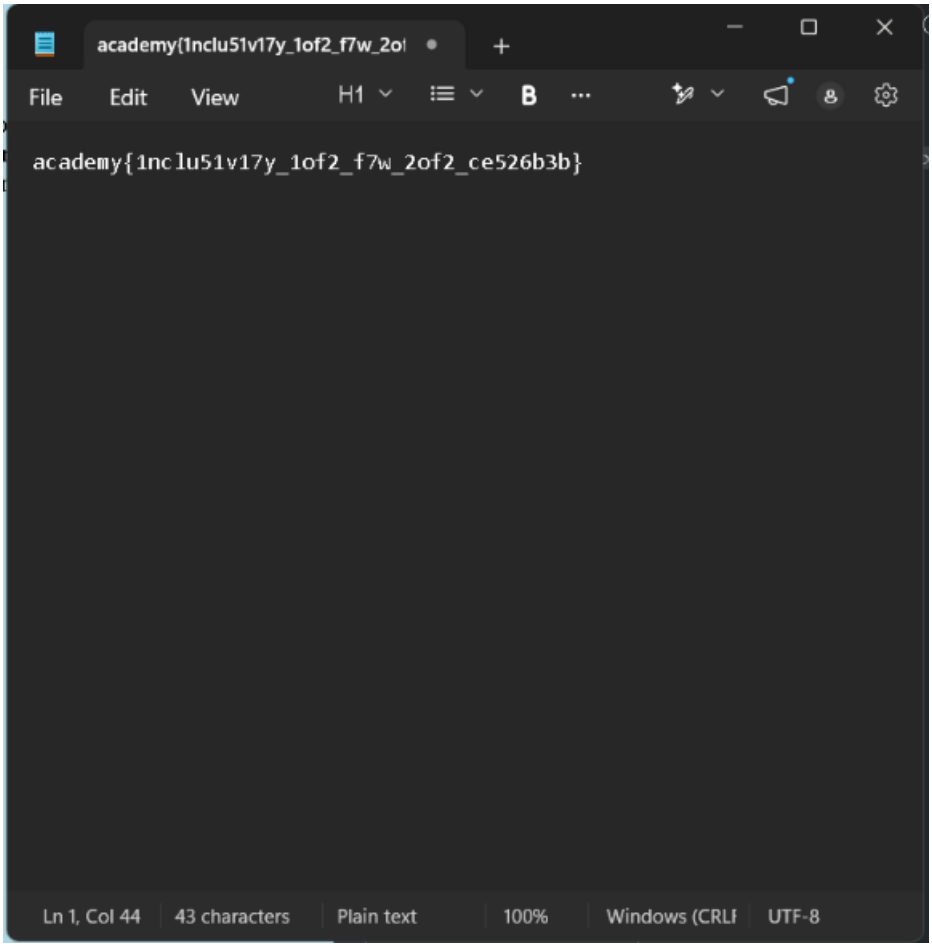


Saat membuka web soalnya, muncul tampilan website sederhana. Terdapat button Say hello yg jika diklik akan memberikan hint dimana code dari website tersebut dibagi oleh beberapa file.





Saya lalu membuka developer tools di bagian source lalu url situs untuk melihat file kodenya. Di bagian style.css dan script.js terdapat komen potongan flag.



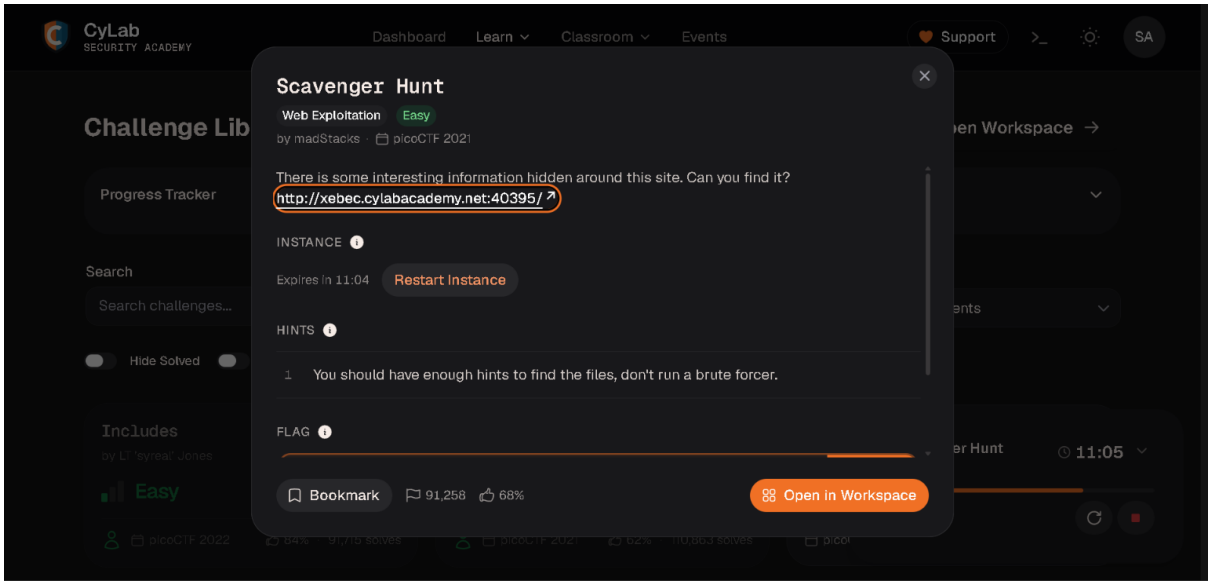
Gabungkan potongan komentar flag tersebut menjadi keseluruhan flag utuh. Flag pun berhasil didapatkan.

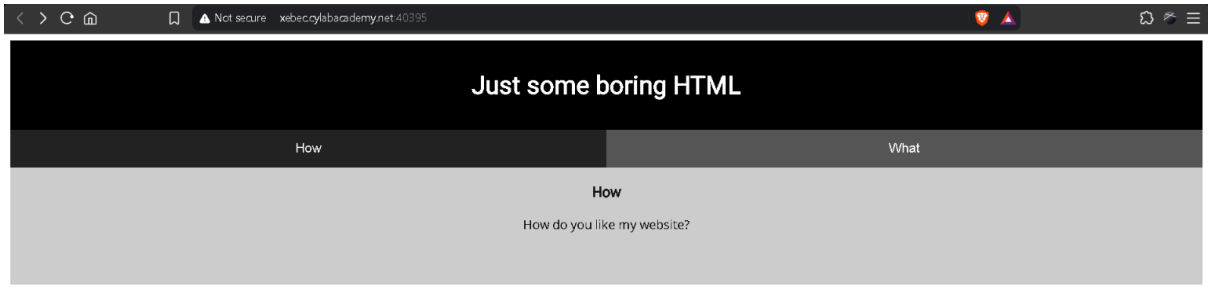
Flag: academy{1nclu51v17y_1of2_f7w_2of2_ce526b3b}

SCAVENGER HUNT

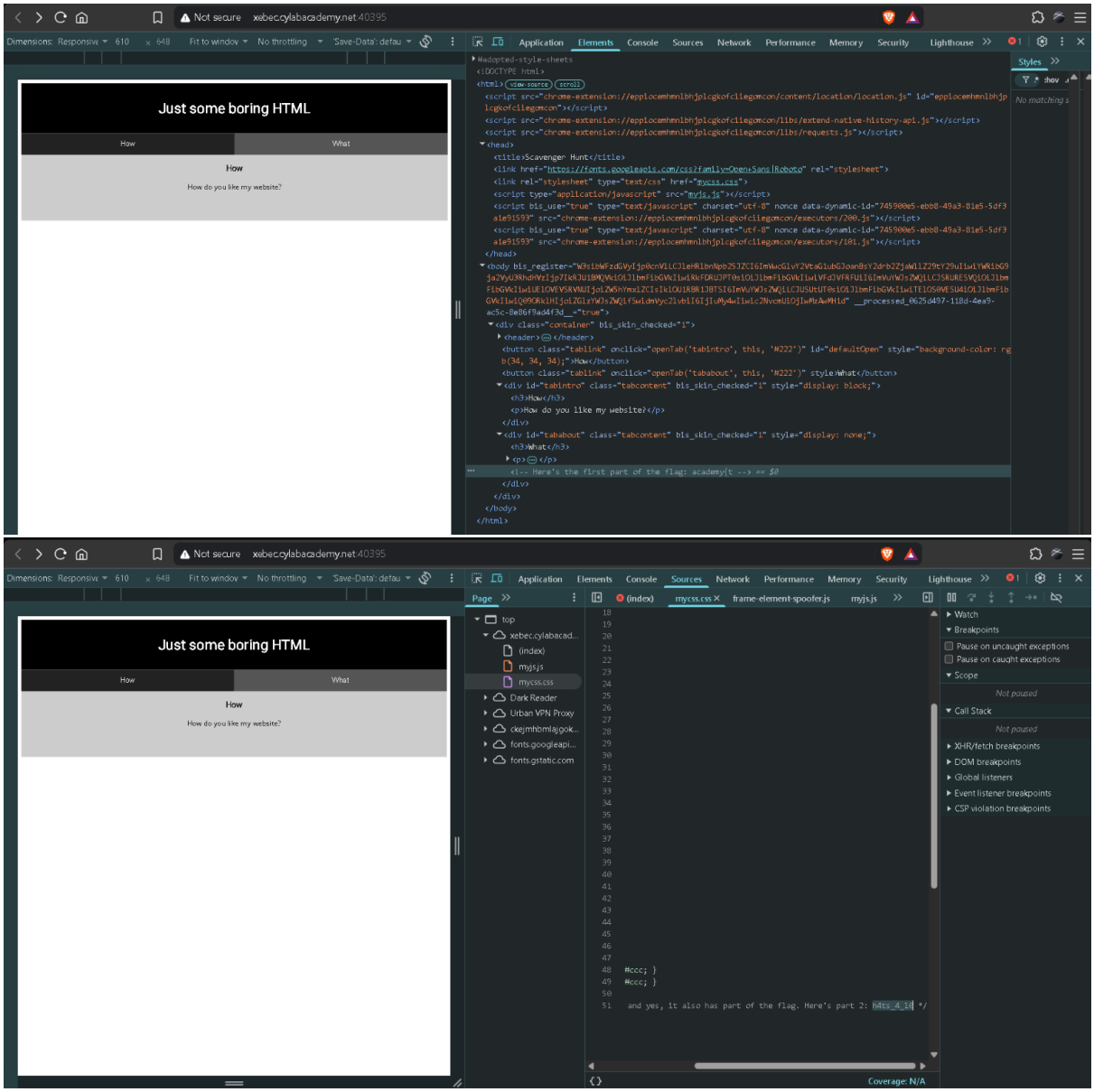
Melakukan pengintaian web dasar untuk mengumpulkan potongan flag yang disebar di berbagai berkas dan konfigurasi situs.

Link: https://learn.cylabacademy.org/library/161

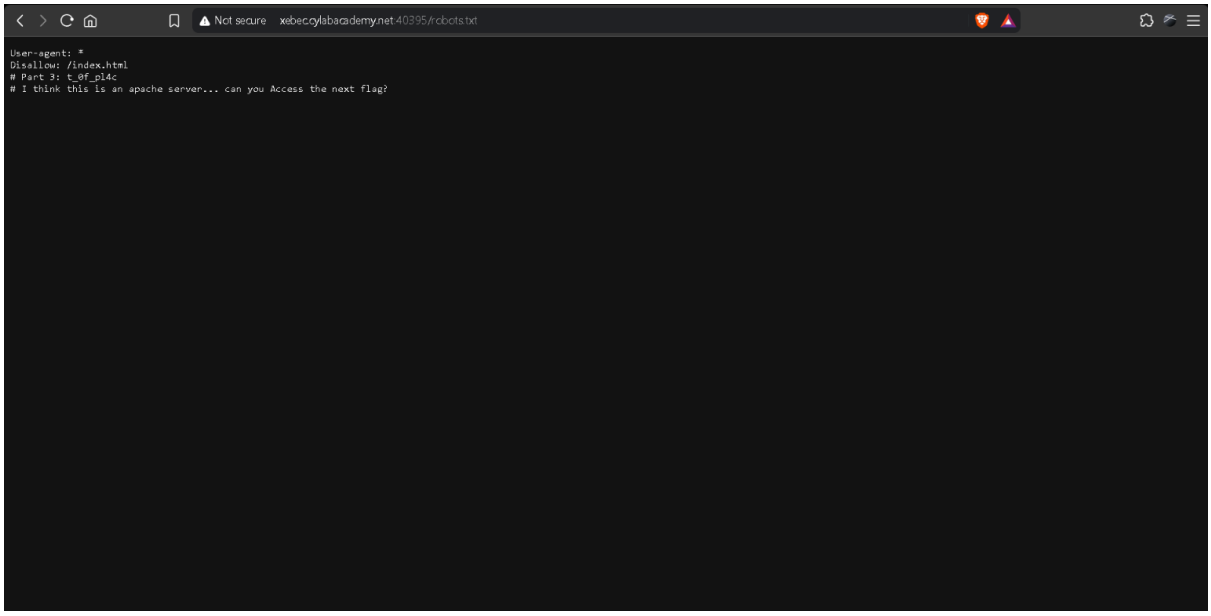




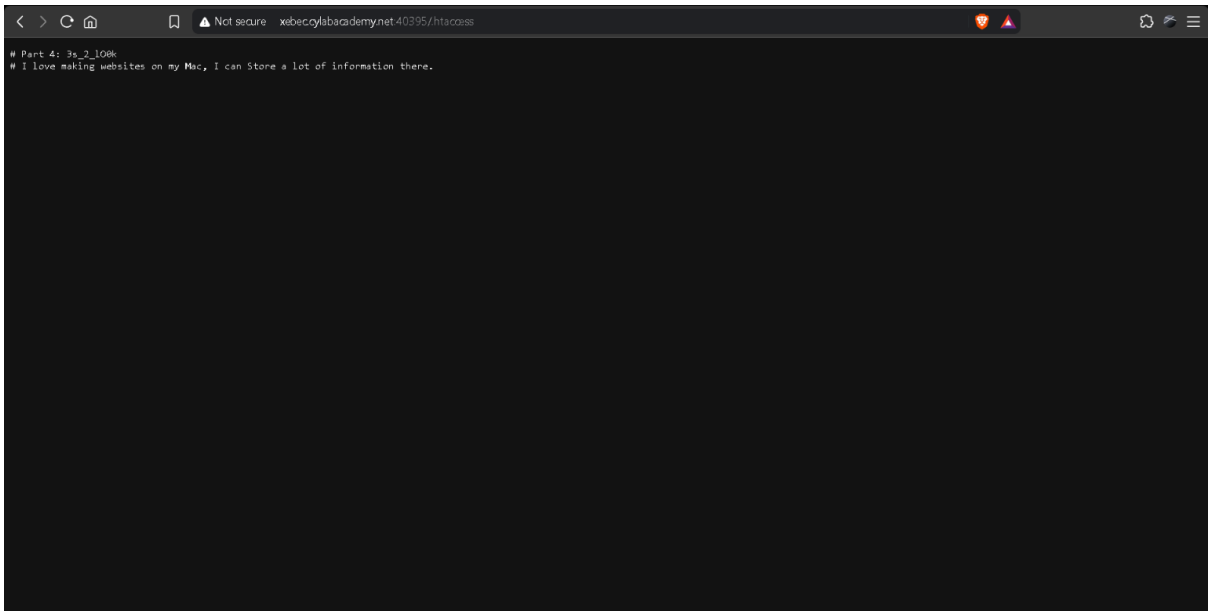
Di website soal, muncul halaman biasa berisikan text “Just some boring HTML”. Terdapat beberapa hint juga seperti How do you like my website?, dan I used these to make this site: html, css, js.



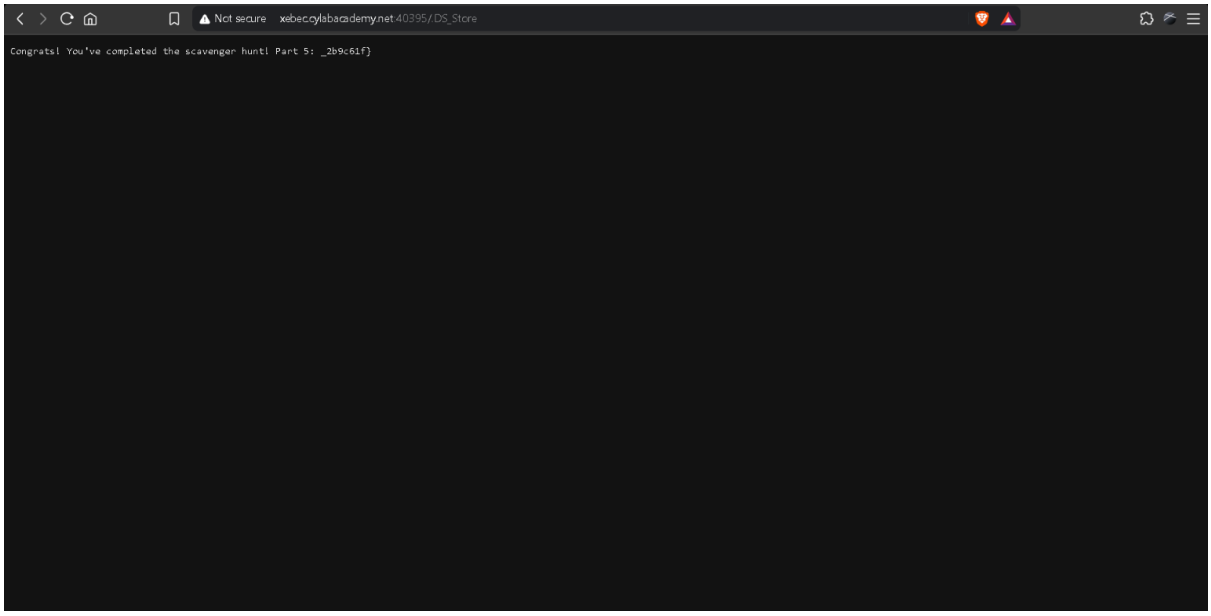
Saya membuka developer tools, lalu pada tab elements saya mendapatkan bagian pertama potongan flagnya, dan di tab sources juga saya menemukan potongan kedua flag pada file css. Di file javascript, terdapat hint “How can I keep Google from indexing my website?” jadi saya mencoba ke path robots.txt



Di file robots.txt saya berhasil mendapatkan potongan ketiga flag. Di sana juga terdapat hint “I think this is an apache server... can you Access the next flag?”.



Lalu saya coba pergi ke path file konfigurasi apache server yaitu /.htaccess dan bagian flag keempat berhasil didapatkan. Di path ini terdapat hint lagi dimana bertuliskan “I love making websites on my Mac, I can Store a lot of information there.”



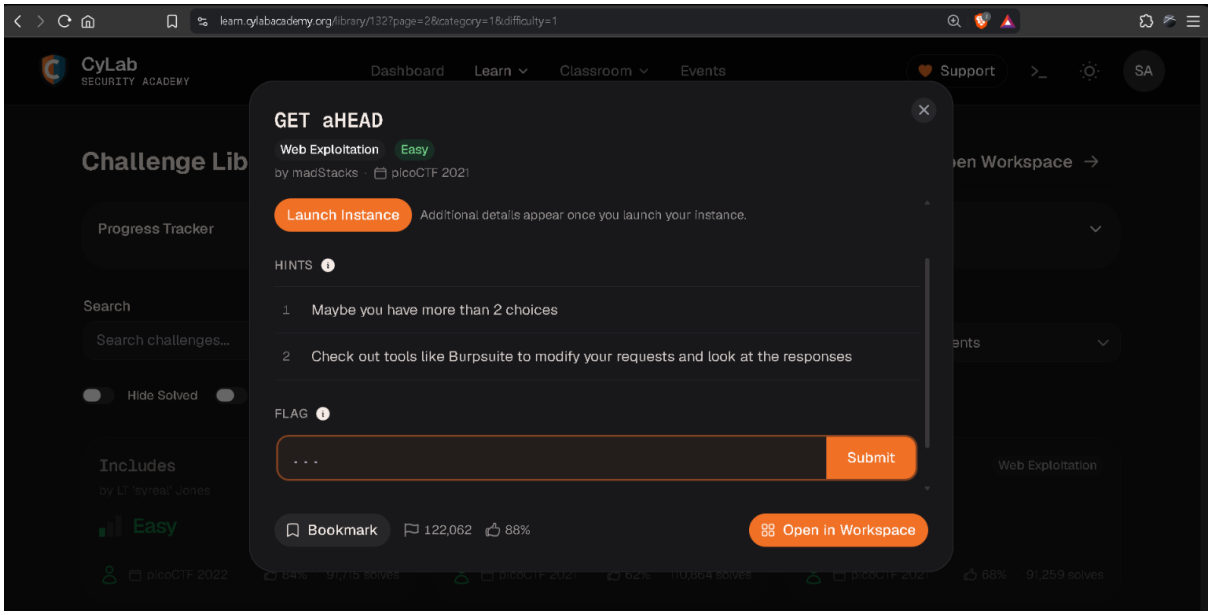
Jadi saya coba pergi ke path metadata bawaan MacOS yaitu /.DS_Store. Bagian ke 5 flag berhasil didapatkan. Gabungkan keseluruhan bagian flag untuk mendapatkan 1 flag utuh.

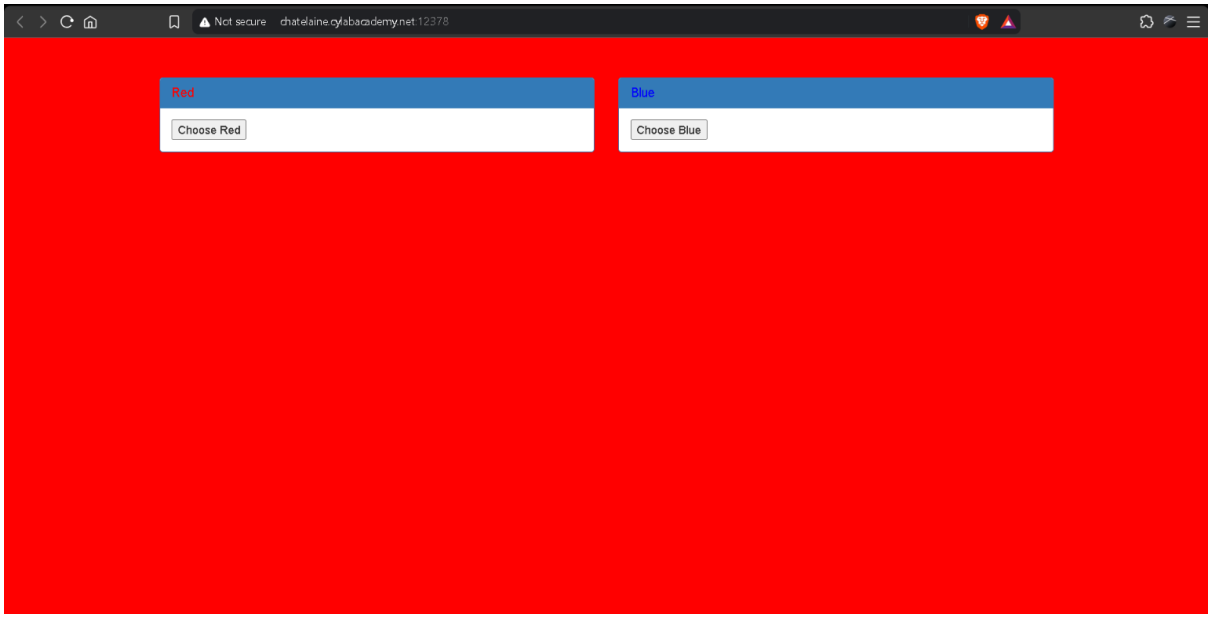
Flag: academy{th4ts_4_l0t_0f_pl4c3s_2_lO0k_2b9c61f}

GET AHEAD

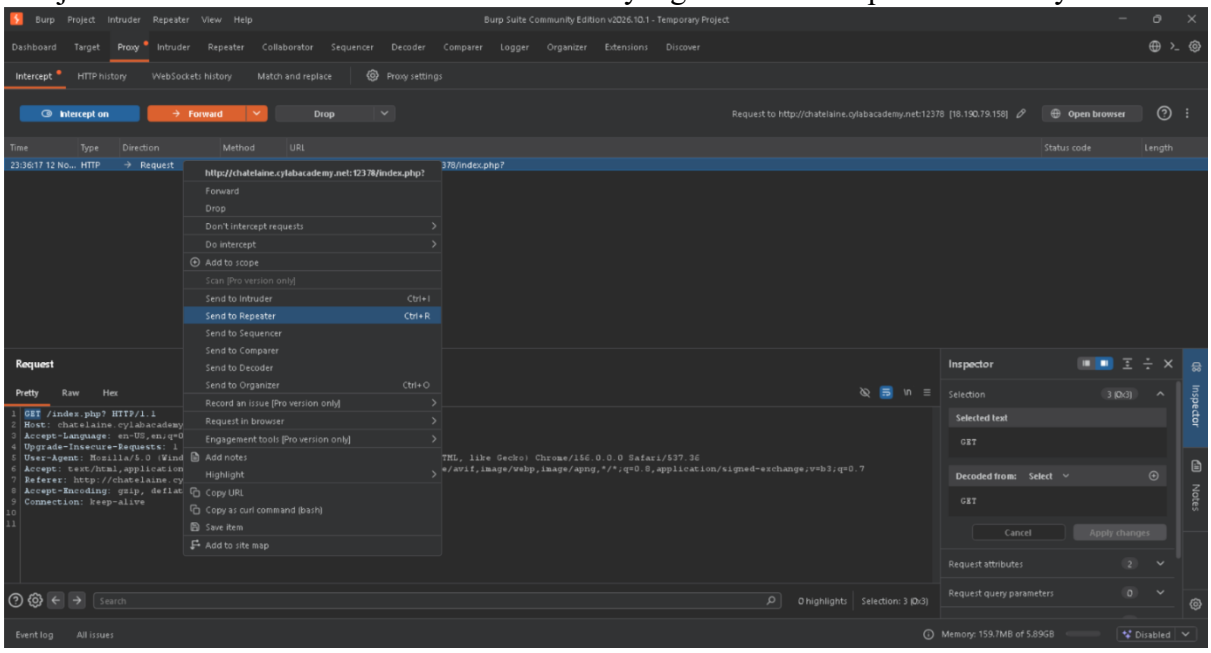
Menemukan flag tersembunyi pada sebuah halaman web sederhana yang menampilkan dua tombol untuk mengubah warna latar belakang (merah dan biru)

Link: https://learn.cylabacademy.org/library/132

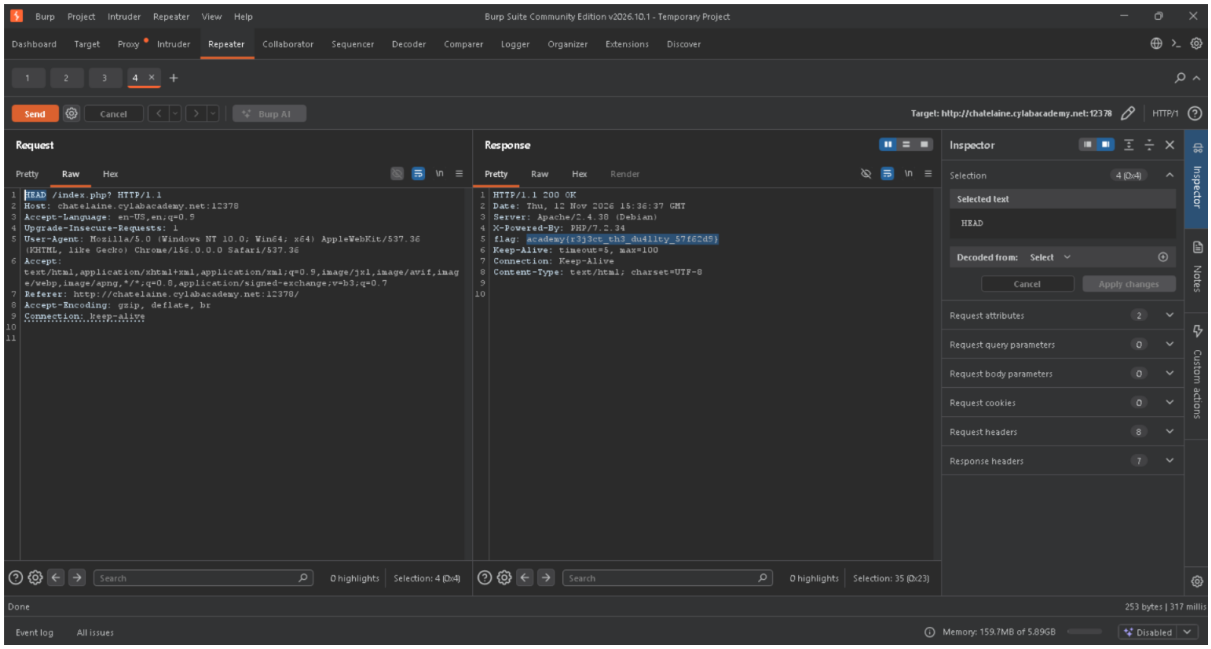




Di website soal, muncul halaman background merah biasa berisikan 2 button choose red untuk mengubah background menjadi merah dan choose blue untuk mengubah background menjadi warna biru. Secara sementara tidak ada yang aneh dari tampilan websitenya.



Saya lalu menggunakan software BurpSuite untuk melakukan analisis request dan respons saat kita menekan buttonnya. Hidupkan intercept mode saat menekan button choose red. Send request header tersebut ke repeater agar mudah di modifikasi untuk melihat responsenya.



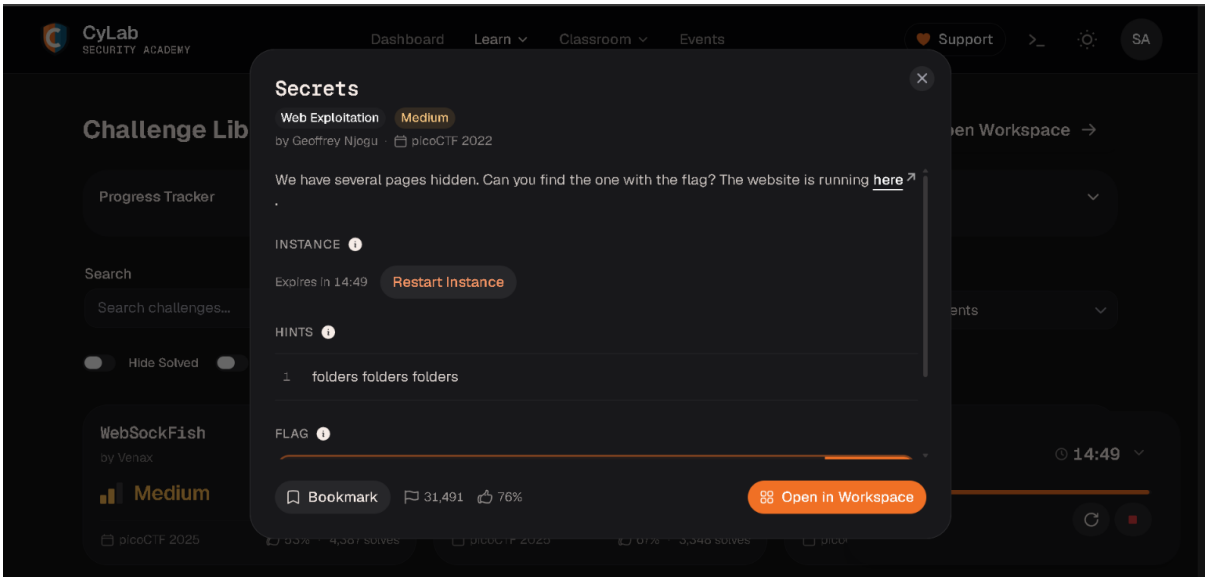
Sesuai nama challenge saya mencoba mengganti di bagian http method “GET” menjadi http method “HEAD” untuk melihat responsenya. Dan benar saja flagnya muncul.

Flag: academy{r3j3ct_th3_du4l1ty_57f62d9}

SECRETS

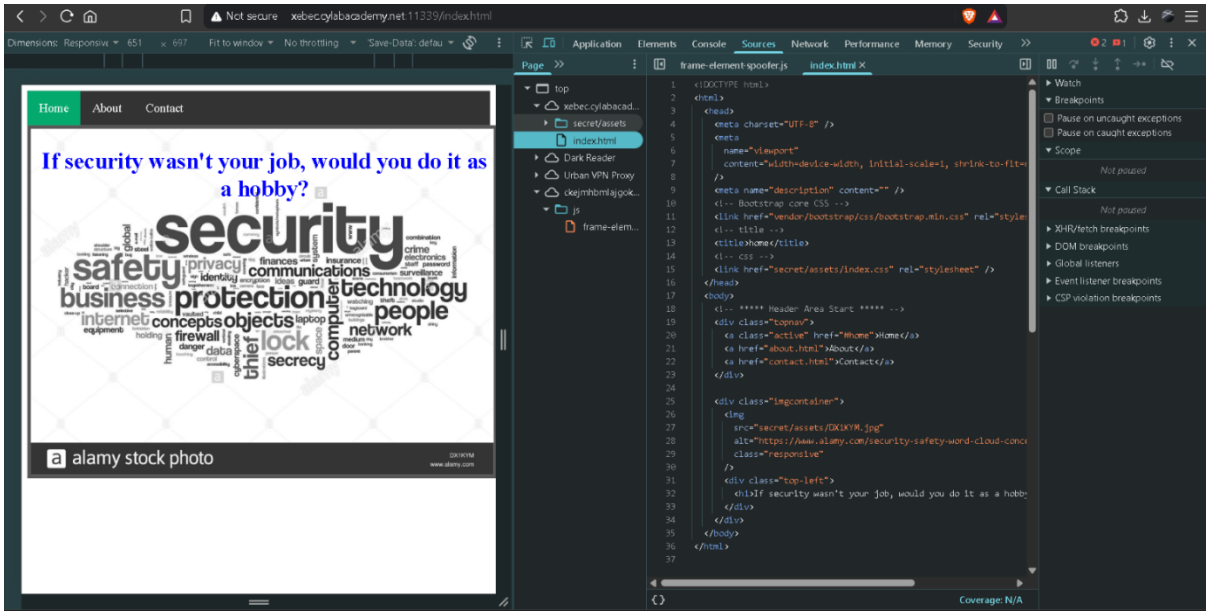
Menguji kemampuan peserta dalam menelusuri struktur direktori tersembunyi di sebuah situs web.

Link: https://learn.cylabacademy.org/library/296

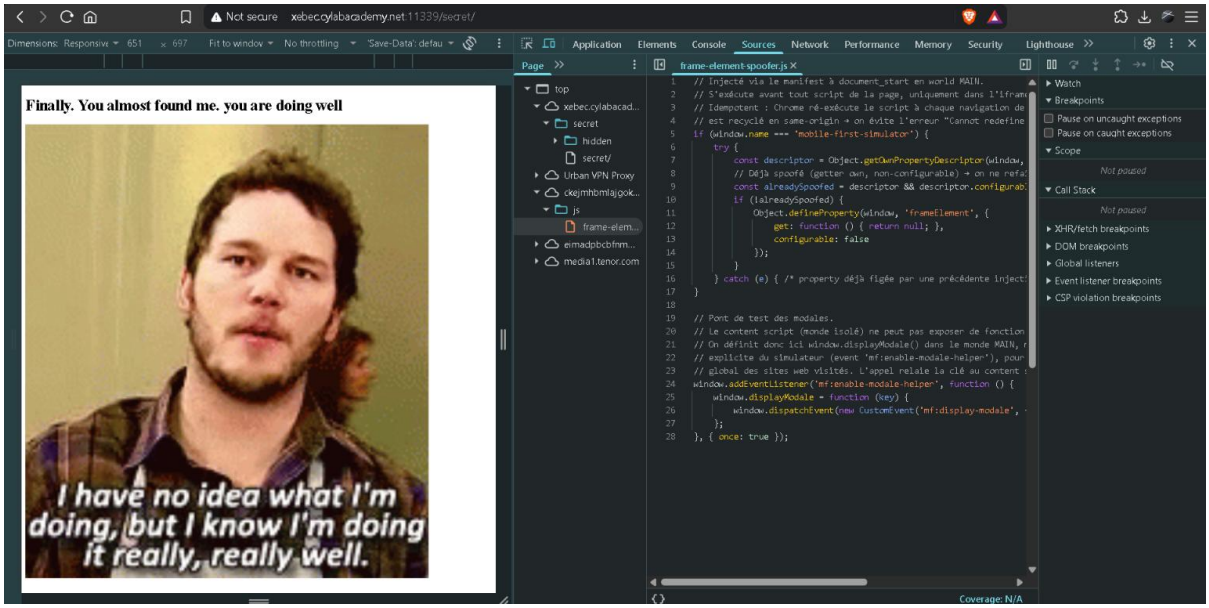




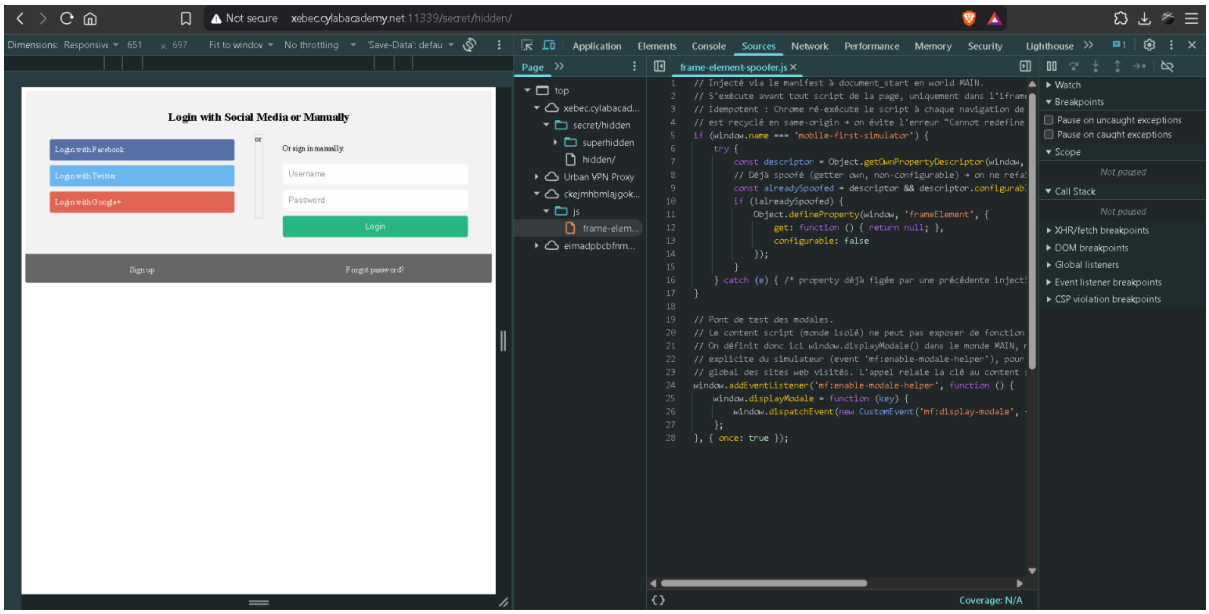
Website soal kali ini menampilkan gambar dan text seperti biasa pada halaman utamanya. Karena mendapatkan hint terkait folders, saya kemudian membuka developer tools untuk mengecek bagian sources.



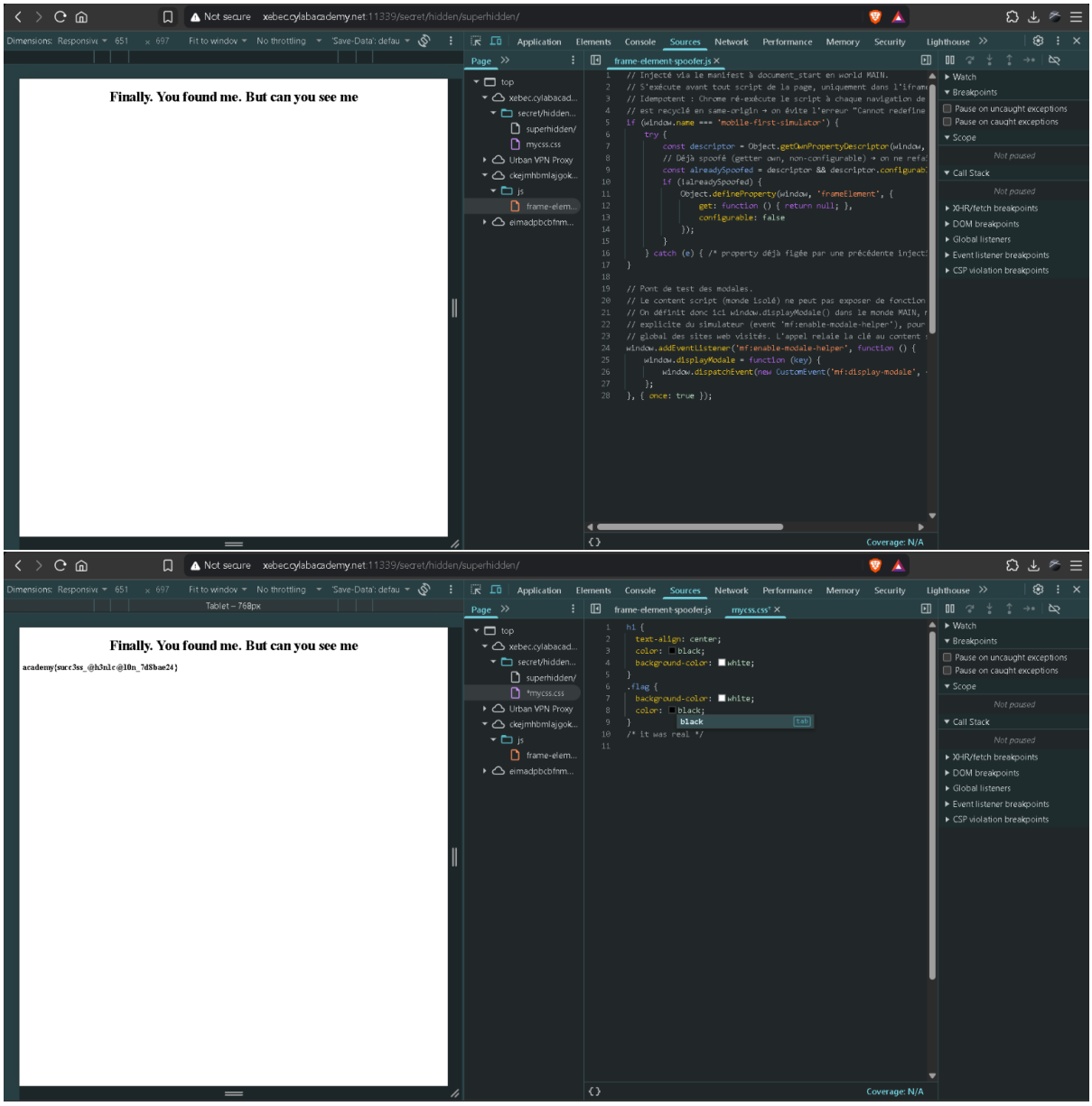
Benar saja terdapat folder secret di tab sources. Saya kemudian mencoba melihat isi folder secret melalui url ditambah /secret/.



Di direktori secret, muncul tampilan gambar dan text “Finally. You almost found me. You are doing well”. Pada bagian direktorinya juga muncul direktori baru lagi di dalam direktori secret yaitu direktori hidden. Saya kemudian melakukan cara yg sama dengan pergi ke path /secret/hidden/.



Setelahnya muncul halaman login. Di bagian direktori muncul lagi direktori baru berjudul superhidden. Saya kemudian melakukan hal sama dengan pergi ke direktori /secret/hidden/superhidden/.



Di direktori /secret/hidden/superhidden/ muncul tulisan “Finally. You found me. But can you see me”, setelah melihat isi kode cssnya, ternyata terdapat text flag yg berwara putih selaras dengan backgroundnya sehingga tidak terlihat. Saya kemudian memodifikasi colornya menjadi hitam untuk melihat dan menemukan flagnya. Flag pun berhasil ditemukan.

Flag: academy{succ3ss_@h3n1c@10n_7d8bae24}